

Incident response process introduction



Contents

Emergency contact details	2
Introduction to the incident response process.....	2
Service provider service level agreements	4
Your responsibilities as the insured	4
Role of the incident response manager	5
Incident response timeline	5

Legal Notice

The information contained in this document is not, nor is it intended to legal advice. We endeavour to provide quality information but make no claims, promises or guarantees about the accuracy, completeness or adequacy of the information contained herein. As legal advice must be tailored to the specific circumstances of each case and laws are constantly evolving, no information provided herein should be used as a substitute for the advice of competent legal counsel.

Incident response process introduction



Emergency contact details

In the event of an actual or suspected incident please notify ITOO as soon as possible on the following contact details:

ITOO Cyber Assist Hotline: 0861 767 778
cyber_claims@ITOO.co.za

Alternatively:

- Ryan van de Coolwijk
+27 83 794 4332
ryanv@ITOO.co.za
- Willie Jansen van Rensburg
+27 82 938 7492
williej@ITOO.co.za

Introduction to the incident response process

The below provides an initial introduction and overview of the typical phases in an incident response process. Many of the services provided in these phases would be provided under a cyber insurance policy as highlighted in the incident response timeline.

First 24 hours checklist

- When responding to an incident time is of the essence. The efficiency and effectiveness of the response can have a big impact on the damages suffered by your organisation as well as affected 3rd parties.
- Where possible and as applicable to an incident, the aim is to have performed the following within the first 24 hours after an incident has been reported/confirmed:
 - Internal incident response team (IRT) notified
 - Initial assessment on the likelihood of the incident performed
 - Executive management notified
 - External IRT notified
 - Legal advice obtained, including guidance on potential regulatory requirements that need to be adhered to
 - Forensic investigation team deployed to investigate and confirm the incident, as well as the nature and extent of data compromised
 - Secure the environment to preserve evidence
 - IT specialists deployed to contain the incident and prevent further loss of data
 - Interview individuals involved in discovering and with insight into the incident
 - If required, take steps to ensure regulatory requirements are adhered to, this could include issuing of initial notifications
 - If required public relations campaign initiated
- Please refer to the templates document "Template C" for an example 24 hour checklist template.

Phase 1: Detection and initial assessment

- Document information relating to the incident and perform an initial likelihood and impact assessment. This will guide whether further investigation and escalation are required.
- Information to document relating to detection of the incident includes:
 - Data and time reported
 - Brief description of the incident
 - Who reported the incident
 - If known, the suspected date and time of the initial breach
 - Reasons for suspecting an incident
 - Who is aware of the incident (media, clients, regulatory bodies etc.)
- Information to document relating to the initial assessment includes:
 - Is the incident suspected or confirmed

Incident response process introduction



- Nature of the incident e.g. lost/stolen device, unauthorised access/external breach etc.
- Nature and number of potentially compromised records e.g. does the data include:
 - Names
 - Contact details
 - ID numbers
 - Financial information
 - Credit card information
- The accessibility/vulnerability of the potentially compromised records e.g. is the data encrypted
- An initial risk rating based on the number of potential affected parties, potential reputational damage and financial losses.
- Please refer to the ITOO Incident report form as repeated in the templates document “Template I” for the ITOO incident report form to be used for initial assessment and information gathering following an actual or suspected incident.

Phase 2: Investigation

- Depending on the nature of the incident, additional investigation may be required.
- Investigations should be documented with care taken not to damage forensic evidence, it is strongly recommended that specialist forensic investigators be used for detailed investigation.
- The aim of the investigation is to confirm the nature and extent of the incident including:
 - Nature of the incident e.g. attack, theft or loss of a device
 - Potential perpetrators, external or internal e.g. malicious employees
 - Potential nature and volume of data that could have been compromised
 - When the breach occurred and which systems were compromised
 - Is the breach ongoing and how can it be contained
- The outcome of the investigation phase will assist in determining the severity of the breach and actions to take within the containment phase. It is important to involve legal counsel throughout the investigation and containment phases.
- The investigation phase typically runs in parallel with the containment phase.
- Please refer to the templates document “Template E” for an example forensics investigation form template.
- Please refer to the templates document “Template F” for an example evidence collection and chain of evidence form template.

Phase 3: Containment

- During the containment phase actions are taken to continue/restore operations while limiting damages to your organisation and affected 3rd parties.
- The various IRT members should be included during this phase, in particular the incident response advisor and internal primary contact. There could be conflicting interests during this phase, in particular between restoring operations and limiting further exposure.
- It is critical to ensure that legal guidance is obtained throughout the containment phase.
- Where the internal team does not possess the required knowledge or expertise, external assistance should be sought. This is particularly important where actions taken could jeopardise the later admissibility of forensic evidence. It is strongly recommended to use professional service providers for these activities.
- Potential actions to stop an ongoing breach and/or continue/restore operations while limiting further exposure include:
 - Segmenting networks
 - Taking selected services offline
 - Moving over to alternate devices or processing facilities
- Depending on the nature of the incident, to limit potential damage and ensure regulatory compliance the following processes may be initiated during the containment phase:
 - Crisis communications and public relations campaign
 - Notifications to external affected parties
 - Notifications to law enforcement agencies
 - Provision of monitoring and remediation services to affected parties e.g. credit and identity theft monitoring
 - Representations to regulatory bodies
- Please refer to the templates document “Template D” for an example incident containment form template.
- Please refer to the templates document “Template G” for an example incident investigation form template.



Incident response process introduction

- Please refer to the templates document “Template H” for an example notification log template.

Phase 4: Eradication and recovery

- Using insight obtained from previous phases plan a clean-up of the environment to remove vulnerabilities exploited by intruders, hacker tools and backdoors introduced by intruders as well as implement areas of improvement identified from prior phases.
- A phased, big-bang or hybrid approach can be adopted:
 - With a phased approach systems or vulnerabilities are resolved over time, systematically working through the environment
 - With a big-bang approach the environment may be brought offline and the identified vulnerabilities resolved before bringing the environment back up.
- Monitoring as part of the eradication and recovery phase is important to ensure the effectiveness of resolution steps taken.

Phase 5: Post incident activities

- Prepare an incident closure report documenting the following:
 - An overview of the incident
 - Response actions taken
 - Eradication and recovery measures implemented
 - The date the incident was closed and who approved the incident for closure
- Conduct a post-incident debrief, considering lessons learned and areas for improvement. These insights should be incorporated into the incident response plan.
- Please refer to the templates document “Template K” for an example incident closure report template.

Service provider service level agreements

The insurer (ITOO) has entered into service level agreements with various service providers for the provision of services as covered under the Insuring Agreements of the Policy. The terms of the service level agreements are applicable to you (the Insured) as if you had signed these service level agreements yourself. The reason for this is to reduce any potential delays in deploying service providers to respond to an incident. The service level agreements are available to you on request from [cyber@ITOO.co.za](mailto:cyber@itoo.co.za). Should you not receive prompt response from this email address or have any questions in this regard, please contact Ryan van de Coolwijk on 083 794 4332

Your responsibilities as the Insured

Apart from activities identified in the incident response timeline later in this document, in order to assist with the efficiency and effectiveness of the incident response process, there are certain requirements expected of you the insured. These include the following:

- Assigning a primary contact to the service providers who have the authority to arrange access, schedule testing and manage any issues that may arise. The primary contact should be available to the service providers as reasonably required throughout the incident response process.
- Promptly and in a timely manner providing information and access to systems that the service providers may reasonably require during the incident response process.
- Informing the service providers in writing of any specific security and access standards or requirements that you require they adhered to.
- Making reasonable efforts to accommodate the service provider teams’ onsite, providing office equipment, telecommunications equipment and information technology as may be reasonably required. Any office equipment, telecommunications equipment and information technology supplied shall at all times remain your property and service providers will return all such equipment and technology as well as delete all such computer software from their computers upon completion of their role on the incident response process.
- Ensuring that any material and access provided to the service provider will not infringe on any intellectual property rights or other rights of any third parties.

Incident response process introduction



Role of the incident response manager

The Incident Response Manager (IRM) plays a crucial role acting as a single point of contact between you (the insured), the insurer (ITOO) and the incident response service providers, as well as coordinating and managing the incident response process.

Below follows an overview of the role of the IRM:

1. Once a claim is notified under the policy to the insurer, the insurer has an election to appoint an IRM. The IRM (typically an attorney) will be appointed by the insurer and will become your main point of contact in dealing with the claim.
2. The IRM will contact you to ascertain details about the claim and the cyber incident or breach. The IRM requires your full cooperation in dealing with the claim.
3. The IRM will appoint the necessary service providers to investigate or assist with the cyber incident or breach insofar as these services fall within the ambit of the policy and if the IRM deems it necessary to do so.
4. The IRM will provide the service providers with instructions and the service providers will only act on instructions of the IRM.
5. In order to protect your rights, that of the service providers and that of the insurer, all correspondence and communications are to be routed via the IRM.
6. The IRM will assess whether there is any regulatory or related obligations imposed on you by law and will liaise with the regulatory authorities in this regard on your behalf.
7. The IRM will liaise with law enforcement agencies in relation to the claim if it is considered necessary to do so.
8. The IRM will communicate with any third parties who express the intention of holding you responsible for the consequences of a cyber breach or incident.
9. No information about the claim, the cyber breach or incident should be made publically available. The IRM will be responsible for managing the public relation functions relevant to the claim if it is necessary to do so.
10. All correspondence received in relation to a cyber breach or incident is to be provided to the IRM.
11. The IRM will update you and insurers on the investigations and handling of the claim on a regular basis.
12. Please note that all actions undertaken by the IRM is done without prejudice to the insurer's rights in terms of the policy or in law.

Incident response timeline

Legend:

- EIRH - Emergency incident response hotline
- IRM - Incident response manager
- DSP - Deployed service providers

On boarding

Timeframe	Activity	Responsibility
Upon issuing of policy documentation	Provision of incident response introduction documentation	ITOO / Broker
Within 30 days of policy document receipt	Completion and provision of insured key contact sheet to ITOO	Insured

Incident response following an actual or suspected incident

Timeframe	Activity	Responsibility
Within 1st hour from notification	Complete and send the ITOO incident report form to cyber_claims@itoo.co.za	Insured
	Notify the ITOO cyber assist hotline	Insured
	Confirmation of key incident details and preliminary logistical information e.g. insured key contact information	EIRH / Insured
	Assign unique incident reference number and verification of policy	EIRH / ITOO
Within 3 hours	Contact incident response service providers	EIRH
	Update ITOO	EIRH

Incident response process introduction



Timeframe	Activity	Responsibility
	Confirm with the insured the service providers to be deployed and key contacts	EIRH / Insured
	Depending on the nature and severity of the incident deploy the IT/forensic service provider to investigate and contain the incident	EIRH
	IT/forensic services provider call to the insured to: - Conduct initial consultation - Advise on next steps as well as “do’s and don’ts” - If deploying tools and resources onsite, arrange details and requirements with the insured	IT/forensics services provider / Insured
	Update ITOO	IT/forensics services provider
	Depending on the incident notify and handover to IRM	EIRH / IRM
	Notify broker	Insured
3 - 12 hours	Establish and confirm a single point of contact	IRM
	Co-ordinate update/briefing with all relevant service providers and key contacts of the insured	IRM
	Deploy additional service providers as are necessary with instructions	IRM
	Access and resources provided to service providers as required	Insured / DSP
	Deployed resources started containment and investigation	Insured / DSP
Within 24 hours	Deployed service providers report back to IRM, insured and ITOO with initial findings.	DSP / IRM
	Consider notification requirements. If various jurisdictions are involved, mobilise resources in various jurisdictions	IRM
	Consider notification to law enforcement agencies	IRM / Insured
	Devise response / mitigation plan and strategy	DSP / IRM / Insured / ITOO
24 to 72 hours	Deployed service providers report back to IRM, insured and ITOO on assessment and actions taken. Planning on next steps as required.	DSP / IRM / Insured / ITOO
	Practical implementation of response / mitigation plan	DSP / IRM / Insured / ITOO
	Report back between insured / IRM / ITOO	Insured / ITOO / IRM
After 72 hours	Deployed service providers report back on investigation and containment of the incident. Planning on next steps as required.	DSP / IRM / Insured / ITOO
	Assessment of exposure (e.g. monetary and reputational)	IRM / Insured / ITOO
	Decide on notification and remediation requirements	IRM / Insured / ITOO
	Coordinate notification and remediation services (clients, employees, service providers, financial institutions and regulators)	IRM / Insured / ITOO
	Notification texts including call center scripts finalised	Crisis Comms provider / IRM / Insured / ITOO
	Notification and remediation service providers instructed and deployed	IRM
	Report back between insured / IRM / ITOO	Insured / ITOO / IRM
Thereafter	Deployed service providers to report back on investigation and containment of the incident. Planning on next steps as required.	DSP / IRM / Insured / ITOO
	Continuing with mitigation and incident response plan	DSP / IRM / Insured / ITOO
	Continuing to comply with regulatory requirements	DSP / IRM / Insured / ITOO
	Assessment of any change in circumstances	IRM / Insured / ITOO
	Monitor costs / cover / exposure	DSP / IRM / ITOO
	Advice on recovery against third parties	IRM
	Incident finalisation and close out report generated and signed off	IRM / Insured / ITOO

Incident response process introduction



Timeframe	Activity	Responsibility
	If applicable, recovery of amounts to the applicable deductible	Insured / ITOO

Annual update

Timeframe	Activity	Responsibility
Annually on renewal	Update and provision of insured key contact sheet to ITOO	Insured

Depending on the nature of the incident as well as well it is identified and notified, the implementation of the timeline is fluid in nature.